AI risk management: addendum to the reference architecture

How NIST AI RMF and Government of Canada instruments shape the controls

Enterprise Architecture · 4 November 2026

[Insert official FIP signature and Canada wordmark]

1

The frameworks

Which instruments apply to us, and how NIST gives them one working structure.

GOVERNMENT OF CANADA INSTRUMENTS (1 OF 2)

Three instruments set our core duties

Instrument	Issued by	What it gives us	Applies to
Directive on Automated Decision-Making, with the Algorithmic Impact Assessment (AIA)	Treasury Board Secretariat (TBS)	Mandatory. Complete the AIA before production. Safeguards rise with impact level I to IV	Systems that make or help make administrative decisions about clients
Privacy impact assessment (PIA), under the Directive on Privacy Practices	TBS	Assess privacy risk where personal information may feed a decision about a person	Programs and activities that use personal information
Guide on the use of generative AI	TBS, 2023; updated Feb 2024	Guidance. FASTER principles; restrict use to risks you can manage	Any institution exploring or deploying generative AI

Reading the status

— The Directive and the privacy requirement are mandatory. The generative AI guide is guidance, but it is the closest thing to a federal checklist for tools like ours.

Sources: TBS Directive on Automated Decision-Making; Privacy Commissioner PIA overview (priv.gc.ca); TBS gen AI guide (canada.ca).

GOVERNMENT OF CANADA INSTRUMENTS (2 OF 2)

Three more instruments add security and direction

Instrument	Issued by	What it gives us	Applies to
Guide on Departmental AI Responsibilities	Chief Information Officer of Canada, Jan 2026	Guidance on governing and managing departmental AI projects	Departmental CIOs and AI governance
Generative AI, ITSAP.00.041	Canadian Centre for Cyber Security, Jul 2023	Cyber risks and mitigations, at awareness level	Organizations and individuals
AI Strategy for the Federal Public Service 2025 to 2027	TBS, Mar 2025	Direction in four priority areas, including policy and governance	The federal public service

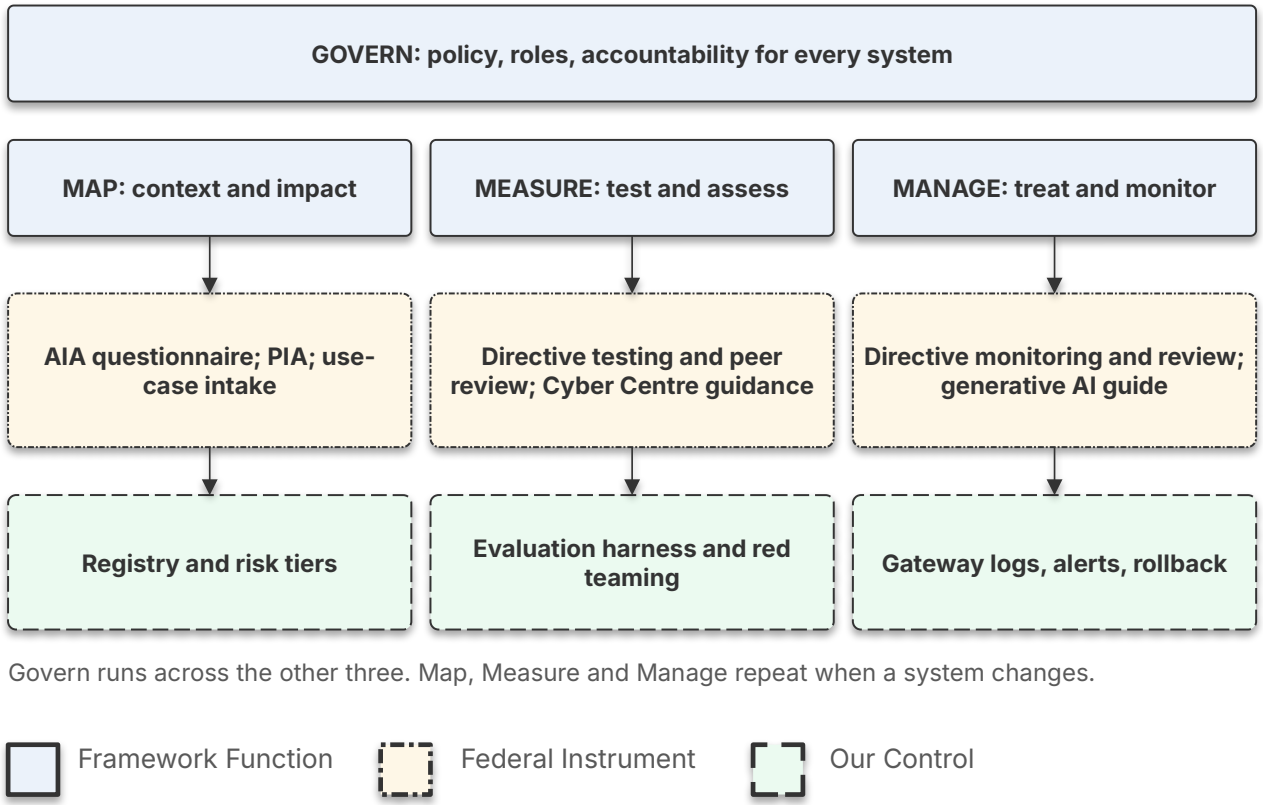
Where NIST fits

— The NIST AI Risk Management Framework is not in these tables. It is a voluntary US framework, not a federal instrument. This addendum uses it as the working structure and maps the federal duties onto it.

Sources: publications.gc.ca catalogue records; Cyber Centre ITSAP.00.041; TBS AI strategy pages on canada.ca.

MY READ

NIST gives the process, federal rules the duties



Govern runs across the other three. Map, Measure and Manage repeat when a system changes.

Figure 1 — NIST functions, federal instruments and architecture controls

How to read it

- Each column is one NIST function. Read down to see the federal duty, then the control that meets it.
- The middle row is the only mandatory row, and only for decisions about clients. The rest is guidance.
- The controls row is what this architecture provides, so project teams do not rebuild it.

Source: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1, Generative AI Profile (Jul 2024). Mapping: my read.

STATUS OF EACH INSTRUMENT

Some instruments are mandatory, others guidance

Mandatory for federal institutions

— Directive on Automated Decision-Making, for administrative decisions

— Algorithmic Impact Assessment before production, results released

— Privacy impact assessment where personal information feeds a decision about a person

Guidance or voluntary

— Generative AI guide (FASTER)

— Guide on Departmental AI Responsibilities

— Cyber Centre ITSAP.00.041

— NIST AI RMF and its generative AI profile

Sources: TBS Directive on Automated Decision-Making; TBS gen AI guide; NIST AI RMF. Grouping: my read.

2

The risks

NIST names twelve generative AI risks. Each one needs a home in the architecture.

CONTENT RISKS

Six risks sit in what the model says

NIST risk	In plain words	Control in the architecture	Concern
Confabulation	Confident output that is false	Grounded retrieval with citations; human review of client-facing output	High
Information integrity	Misleading content that looks real	Notice that AI is used; sources shown in every answer	Medium
Harmful bias and homogenization	Unequal results across groups or languages; sameness of output	Evaluation by subgroup and language; AIA fairness questions	High
Dangerous, violent or hateful content	Output that incites or instructs harm	Output guardrails; provider filters	Medium
Obscene, degrading or abusive content	Abusive or synthetic harmful material	Output guardrails; acceptable-use rules	Lower
Intellectual property	Reproduces protected work, or leaks ours	Approved providers; contract terms on training use	Medium

About the Concern column

— Ratings are my read. The Board should rescore them for each use case.

Source: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1, Generative AI Profile (Jul 2024).

Six risks sit in the system and its data

NIST risk	In plain words	Control in the architecture	Concern
Data privacy	Leak, memorize or re-identify personal information	Index, do not copy; rights-aware retrieval; PIA; hosting grid	High
Information security	Prompt injection, data poisoning, model theft	Gateway filters; scoped tokens; red teaming	High
Value chain and component integration	Hidden risk in vendors' data, models and parts	Approved provider list; component inventory; contract terms	High
Human-AI configuration	Over-reliance or misuse at the human hand-off	Human approval points; training before access	Medium
Environmental	Energy and water use of large models	Usage reporting at the gateway; right-sized models	Lower
CBRN information or capabilities	Easier access to weapons information	Provider safeguards; output guardrails	Lower

Why value chain rates High

— We depend on hosted models we cannot inspect. A silent provider change can affect every use case.

Source: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1, Generative AI Profile (Jul 2024). Ratings and controls: my read.

MY READ

Six controls sit along the request path



1 Input filter: prompt injection, dangerous requests (information security, dangerous content).

2 Retrieval: restricted passages stay out of the prompt (data privacy).

3 Model: evaluated before release; version pinned (confabulation, bias, value chain).

4 Output guardrails: leaked identifiers, abusive content, missing citations (privacy, content risks).

5 Approval: a person confirms any action that changes records or sends messages (human-AI configuration).

6 Logging: every call kept so incidents can be traced and reviewed (all risks).

Our Control

Figure 2 — Risk controls along the request path

Why along the path

— Controls built into the path protect every use case, including ones nobody has thought of yet.

— Controls 1 to 4 run on every call. Control 5 runs only where an action changes something.

— Control 6 is what lets an auditor trace any answer back to its sources and approver.

Source: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1, Generative AI Profile (Jul 2024). Mapping: my read.

3

Assessing and tiering

A short path from a new idea to the right assessments, scaled to risk.

Risk tier decides which assessments apply

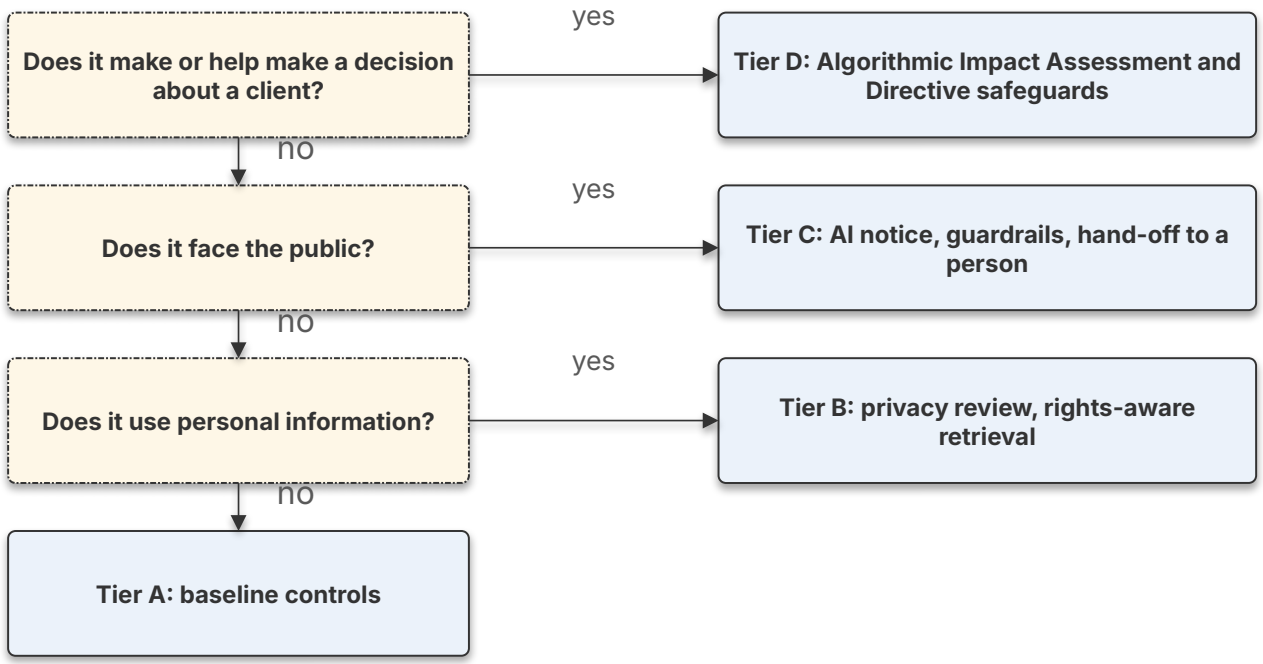
Tier	Example	Assessments	Added controls	Approver
A Staff aid, no personal information	Drafting help; summarizing public documents	Generative AI guide self-check	Gateway logging; training	Program manager
B Staff aid, personal information	Summarizing case files for an officer	Privacy review or PIA update; security review	Rights-aware retrieval; Canadian-region hosting	Director, with privacy officer
C Public-facing information	Chatbot answering from published content	Security review; language and accessibility review; PIA if personal information	AI notice; output guardrails; hand-off to a person	Assistant deputy minister, with CIO
D Decisions about clients	Eligibility triage; risk scoring	Algorithmic Impact Assessment; peer review; PIA	Human makes the final call at higher levels; published results; recourse	As the Directive sets, by impact level

Status of this table

— The tiers and approvers are my proposal. Only Tier D rests on a mandatory instrument. Confirm approvers against departmental delegations.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard. Tier D: Directive on Automated Decision-Making.

Three questions place a use case in a tier



The first yes sets the tier. A public chatbot that also uses personal information stays Tier C and adds a PIA.

Figure 3 — Use-case tiering questions

Keep it to three questions

— A long questionnaire gets skipped. Three questions take a minute and put most use cases in the right place.

— Tier D then uses the federal Algorithmic Impact Assessment to find the impact level. We do not replace it.

— A use case that changes scope, for example a staff aid that starts informing decisions, is tiered again.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

Impact levels raise the safeguards step by step

Level	Impact	Reversibility and duration	What grows with the level
I	Little to no	Reversible and brief	Baseline requirements only
II	Moderate	Likely reversible, short-term	Peer review; public notice; explanation on request
III	High	Hard to reverse, long-term	Stronger peer review; human intervention points; explanation with the decision
IV	Very high	Irreversible and perpetual	Strongest peer review; a human makes the final decision; approval moves higher

Check Appendix C before relying on this

— This follows summaries of the 2019 to 2021 Directive. The Directive was amended in 2025 and I could not open the current text. One secondary source gives 24 June 2026 as the date existing systems must comply. Confirm both.

Source: Treasury Board Directive on Automated Decision-Making; Algorithmic Impact Assessment tool (canada.ca).

4

Running it

Risk is managed over the life of a system: owners, evidence, indicators.

MY READ

Risk is managed in a loop, not signed off once

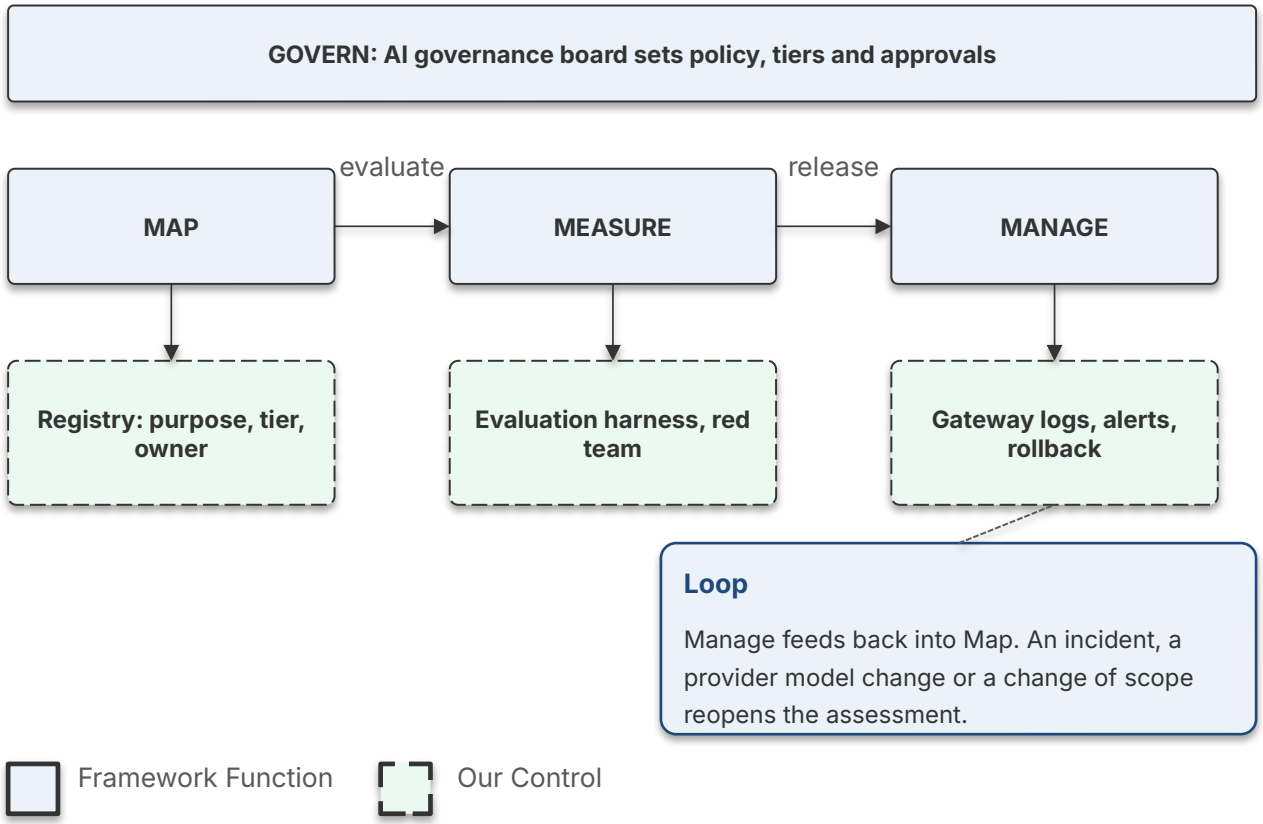


Figure 4 — Risk management loop and supporting controls

What closes the loop

— Each box in the controls row produces evidence: a record, a test result, a log.

— Evidence goes to the governance board, which sees the whole portfolio, not one system.

— NIST describes Govern as running continuously under the other three. That is why it sits across the top.

Source: NIST AI RMF 1.0 (Jan 2023); NIST AI 600-1, Generative AI Profile (Jul 2024). Components: my read.

RISK REGISTER

A starter register: six risks, scored and owned

#	Risk	Likelihood	Impact	Key control	Owner
R1	Confabulation in a client-facing answer	Medium	High	Citations; human review for Tier C and D	Program owner
R2	Restricted passage reaches the wrong user	Low	High	Rights filter at retrieval; test suite	CIO
R3	Prompt injection through a document or tool	Medium	High	Gateway filters; scoped tokens; approval for actions	Chief security officer
R4	Personal information sent to a hosted model	Low	High	Hosting grid; gateway blocks by data class	Privacy officer
R5	Biased outcome in a client decision	Low	Very high	AIA; subgroup testing; human final decision	Program owner
R6	Provider changes a model without notice	Medium	Medium	Pinned versions; re-evaluate on change	Model owner

Illustrative only

— Scores are my read and are there to show the format. The governance board should score the real register using the departmental risk method.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

ROLES

Eight roles carry the accountability

Role	Accountable for
Program owner	The use case, its outcomes and its residual risk
Model or system owner	Evaluation results, changes and incident response for one system
AI governance board	Policy, risk tiers, and approval of Tier C and D use cases
Chief Information Officer	The platform (gateway, index, hosting) and the AI inventory
Chief security officer	Security assessment, red teaming, incident handling
Privacy officer	Privacy impact assessments and privacy review
Enterprise architecture review board	Conformance to this reference architecture
Legal services	Legal review where a decision affects rights or interests

Suggested allocation

— Confirm against departmental delegations and the Guide on Departmental AI Responsibilities.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

INDICATORS

Eight indicators show whether controls work

Indicator	What it tells us	Target
Answers that carry a citation	Whether grounding works (confabulation)	Board sets by tier
Rights-filter failures found in tests	Whether restricted text can leak (data privacy)	Zero
Model calls made outside the gateway	A gap in the single control point	Zero
Use cases with a current tier and owner	Governance coverage	All
Evaluation pass rate before release	Whether Measure is real	Board sets by tier
Incidents by severity, and time to close	Whether Manage works	Falling trend
Human override and escalation rate	Over-reliance or distrust (human-AI configuration)	Watch for sudden change
Provider model changes reassessed	Value chain control	All

> **Illustrative**
>
> — Targets marked "Board sets" need a baseline first. Collect data before choosing a number.

Source: Enterprise Architecture. Judgment: this is my read, not a published standard.

What the sources confirm and what to check

Found in sources

— The Directive requires an AIA before production

— The gen AI guide points to ITSAP.00.041

— NIST AI 600-1 names twelve generative AI risks

— The Guide on Departmental AI Responsibilities is dated 19 Jan 2026

— The old Directive on PIA was rescinded 9 Oct 2024; the requirement sits in the Directive on Privacy Practices

Confirm before relying

— Current Directive text and Appendix C

— The 24 June 2026 compliance date, from one secondary source

— Whether the Departmental guide sets inventory or register duties; I could not open it

— The Privacy Act review launched 2 April 2026, from one secondary source

— Whether the draft AI lifecycle framework in the strategy placemat has been published

Sources: TBS, Privacy Commissioner and publications.gc.ca pages; secondary sources as noted.

Sources and further reading

Government of Canada

Directive on Automated Decision-Making
Mandatory; check Appendix C

Algorithmic Impact Assessment tool
Impact levels I to IV

Guide on the use of generative AI
FASTER principles

Guide on Departmental AI Responsibilities
Jan 2026

Generative AI, ITSAP.00.041
Cyber Centre guidance

Frameworks and context

NIST AI Risk Management Framework
Govern, Map, Measure, Manage

NIST AI 600-1, Generative AI Profile
Twelve generative AI risks

AI Strategy 2025 to 2027
Four priority areas

Privacy impact assessments overview
When a PIA is required

Roadmap to Scale AI Projects
Mar 2026; not reviewed

Links taken from search results on 4 November 2026. The Directive, Departmental guide and strategy pages would not open for me.